Практическое задание к Лекции 2

Тема: «Анализ объектов уязвимости и угроз надёжности для конкретной системы»

Выбранный вариант: Вариант Б. Рабочая станция бухгалтера, на которой хранятся финансовые документы.

Описание системы

Рабочая станция бухгалтера — это персональный компьютер малой организации с операционной системой Windows, бухгалтерской программой (например, 1С:Бухгалтерия) и локальной базой финансовых документов: счета, акты, платёжные поручения, отчётность. Компьютер подключён к интернету и электронной почте, через него бухгалтер работает с интернет-банком по электронной подписи (ЭЦП) и отправляет отчёты в контролирующие органы. Станция работает в течение рабочего дня, а потеря данных или доступа к ним приводит к срыву сроков сдачи отчётности и финансовым потерям.

Шаг 1. Пять объектов уязвимости

№	Объект уязвимости	Категория	Почему это объект уязвимости
1	Накопитель (SSD/HDD) и электропитание рабочей станции	Аппаратный	На нём физически хранятся все данные; от исправности и питания зависит доступность станции.
2	Бухгалтерская программа и операционная система	Программный	Через них идёт вся работа; уязвимы к вредоносному ПО, ошибкам и обновлениям.
3	База финансовых документов (файлы и база 1С)	Информационный	Содержит коммерческую тайну и данные, на которых строится отчётность.
4	Учётные данные и ключ электронной подписи (ЭЦП)	Информационный	Дают доступ к программе, интернет-банку и позволяют подписывать документы от имени организации.
5	Бухгалтер как пользователь станции	Человеческий / организационный	Именно человек вводит данные, управляет доступом и следует (или не следует) правилам.

Шаги 2–4. Дестабилизирующие факторы, угрозы и их классификация

Для каждого объекта выделено по два дестабилизирующих фактора. Классификация: **природа** (внутренний / внешний), **характер** (случайный / преднамеренный), **время действия** (постоянный / периодический / разовый).

Объект уязвимости	Категория	Дестабилизирующий фактор	Классификация фактора	Угроза надёжности	Вид угрозы
1. Накопитель и электропитание	Аппаратный	1.1 Естественный износ накопителя (ограниченный ресурс записи)	Внутренний, случайный, постоянный	Полный отказ накопителя, недоступность всех данных	Отказ
		1.2 Скачки напряжения и внезапное отключение электричества	Внешний, случайный, периодический	Прерывание записи на диск, повреждение файловой системы	Сбой

Объект уязвимости	Категория	Дестабилизирующий фактор	Классификация фактора	Угроза надёжности	Вид угрозы
2. Бухгалтерская программа и ОС	Программный	2.1 Вредоносная программа (вирус-шифровальщик), пришедшая из почты или интернета	Внешний, преднамеренный, периодический	Шифрование файлов, потеря доступа к базе и программе	Блокирование
		2.2 Неудачное обновление ОС или релиза программы (несовместимость версий)	Внешний, случайный, разовый	Программа перестаёт запускаться или работает неверно	Сбой
3. База финансовых документов	Информационный	3.1 Доступ посторонних (оставленный без блокировки компьютер, открытая сетевая папка)	Внешний, преднамеренный, периодический	Попадание финансовых данных к посторонним	Утечка
		3.2 Аварийное завершение программы во время записи в базу	Внутренний, случайный, разовый	Повреждение или потеря записей в базе	Потеря целостности
4. Учётные данные и ключ ЭЦП	Информационный	4.1 Простой пароль, повторно используемый в разных сервисах	Внутренний, случайный, постоянный	Подбор или кража пароля, вход под чужой учётной записью	Утечка
		4.2 Фишинговое письмо или поддельный сайт банка	Внешний, преднамеренный, периодический	Выдача пароля или ключа ЭЦП злоумышленнику	Утечка
5. Бухгалтер (пользователь)	Человеческий / организационный	5.1 Невнимательность и усталость при вводе данных	Внутренний, случайный, периодический	Неверные суммы и реквизиты в документах и отчётности	Ошибка
		5.2 Недовольный или уволенный сотрудник, сохранивший доступ	Внутренний, преднамеренный, разовый	Удаление или искажение документов	Потеря целостности

Использованы все шесть видов угроз: отказ, сбой, ошибка, утечка, потеря целостности, блокирование.

Шаг 5. Меры защиты

По одной мере для каждой выявленной угрозы (номера соответствуют факторам в таблице).

№	Угроза	Мера защиты	Тип меры
1.1	Отказ накопителя	Резервное копирование по правилу «3-2-1» (3 копии, 2 типа носителей, 1 копия вне офиса) и контроль состояния диска (SMART)	Техническая
1.2	Сбой при отключении питания	Источник бесперебойного питания (ИБП) с корректным завершением работы системы	Техническая
2.1	Блокирование данных шифровальщиком	Антивирус с автоматическими обновлениями, работа под учётной записью без прав администратора, отключённые от сети копии данных	Программная
2.2	Сбой после обновления	Тестирование обновлений на другом компьютере, точка восстановления перед установкой, регламент обновлений	Организационная
3.1	Утечка документов	Автоблокировка экрана, разграничение прав доступа к папкам, шифрование диска	Программная
3.2	Повреждение базы при сбое	Регулярная проверка и тестирование целостности базы, резервная копия перед закрытием периода	Программная

№	Угроза	Мера защиты	Тип меры
4.1	Компрометация пароля	Парольная политика (длина, уникальность) и двухфакторная аутентификация	Программная
4.2	Фишинг	Хранение ЭЦП на защищённом токене и обучение сотрудника распознаванию фишинговых писем	Организационная
5.1	Ошибка ввода	Двойной контроль: проверка критичных документов вторым лицом и проверка формата полей в программе	Организационная
5.2	Действия обиженного сотрудника	Отзыв доступа в день увольнения, журналирование действий в базе, минимально необходимые права	Организационная

Шаг 6. Наиболее опасная угроза

На мой взгляд, наиболее опасна угроза **2.1 — блокирование данных вирусом-шифровальщиком** (вид угрозы «блокирование»). Оценка по двум параметрам:

- **Вероятность реализации — высокая.** Рабочая станция бухгалтера постоянно работает с почтой, вложениями и интернет-банком, а письмо с вредоносным вложением — один из самых распространённых способов заражения. Один неосторожный клик способен запустить шифровальщик, а факторы 4.2 (фишинг) и 2.1 часто связаны между собой.
- **Тяжесть последствий — очень высокая.** Шифруются сразу все документы и база 1С, работа полностью останавливается. Организация может не успеть сдать обязательную отчётность в срок, получает штрафы и репутационные потери. Если актуальных копий нет, данные теряются безвозвратно, а выплата выкупа не гарантирует их возврата. Дополнительно возможна утечка копий документов.

Остальные угрозы либо менее вероятны (отказ диска и повреждение базы при сбое), либо менее разрушительны (ошибка ввода исправляется, а сбой после обновления откатывается). Угроза 2.1 сочетает высокую вероятность с максимальной тяжестью, а надёжно снизить её можно мерами 1.1 и 2.1: изолированными резервными копиями, антивирусом и работой без прав администратора.